

GovRed-Health: Benchmarking Authorization Drift Between Governed Disclosure and Persistent Commit

Nguyen Ngoc Thien, Trinh Minh Quang
Hai Ba Trung High School, Hue, Vietnam
Corresponding author: kakangocthen109@gmail.com

Abstract—Stateful health-AI systems may read a governed longitudinal-health disclosure and return a persistent proposal only after patient state, consent, policy, role, purpose, cache state, or snapshot validity has changed. GovRed-Health benchmarks this authorization drift across the disclosure-to-commit interval. Each matched logical schedule issues a governed disclosure, mutates one or more relevant dependencies, and then exercises persistence through the application, authorization, cache/index, PostgreSQL, and audit path. The research arms are mechanism ablations, not claimed implementations of prior systems. In a sealed isolated run, the executable primary set contained 210 schedules per arm. The prespecified original non-safe composite was 57.1% for Unbound, 42.9% for State-Version-Only, 42.9% for Snapshot-Bound-State-Only, and 14.3% for GLHS-Strict. Strict versus Unbound had 90 discordant schedules favoring Strict and none favoring Unbound under that composite. All 30 Strict residuals were concurrent state-state schedules with indeterminate linearization and therefore are not counted as confirmed invalid commits. The tested serial authorization-drift families produced zero confirmed invalid Strict commits; prohibited disclosure was 0/270 in every arm. The benchmark supports a bounded software governance-consistency claim, not a general cybersecurity or clinical-effectiveness claim.

Index Terms—health AI, healthcare data governance, authorization drift, TOCTOU, consent, persistent agents, benchmark

I. INTRODUCTION

Stateful health AI repeatedly reads from and may later add to a longitudinal record. This creates a cross-operation problem: a disclosure can be valid when shown to a model but no longer be a valid basis for a durable effect after consent, policy, role, purpose, patient state, cache state, or snapshot validity has changed.

This problem is narrower than prompt injection. AgentDojo benchmarks prompt injection against tool-using agents [1]; Agent Security Bench evaluates multiple attack and defense families [2]; MPIB focuses on direct and RAG-mediated prompt injection in clinical tasks [3]; and SecureClaw combines sensitive-read confinement with external-effect authorization [4]. A separate line of work is closer still: commit-time authorization shows that previously valid authority can become stale before durability [5]; Provenact formalizes policy-state serializability for concurrent effects [6]; and GateMem benchmarks access control and forgetting in multi-principal memory [7].

GovRed-Health therefore makes a narrower claim. It asks what happens after a *governed health disclosure has actually been consumed by a model* and one of the dependencies of that disclosure or later write changes. The benchmark treats

the disclosure, intervening mutation, commit attempt, and audit reconstruction as one matched schedule rather than reducing the experiment to model attack success or endpoint success.

Its contributions are: (1) a frozen schedule abstraction that includes the model-visible governed disclosure in the experimental unit; (2) matched state and governance mutations across subject, consent, policy, role/purpose, state, cache, snapshot, and audit dimensions; (3) execution through real application and persistence boundaries; and (4) an analysis contract that keeps safe rejection, service failure, and indeterminate concurrent ordering distinct.

II. NOVELTY BOUNDARY AND THREAT MODEL

A. What GovRed-Health does not claim

GovRed-Health does not introduce prompt injection, access-control testing, governed memory, dual-boundary enforcement, optimistic concurrency, commit-time authorization, or policy-state serializability. The four system configurations are internal mechanism ablations and are not claimed as faithful implementations of AgentDojo, SecureClaw, CommitGuard, Provenact, GateMem, or another published system.

B. Authorization drift object

Let an issued governed disclosure be

$$H = (u, a, p, v_s, v_g, d, e, E), \quad (1)$$

where u is subject, a actor, p purpose, v_s state version, v_g governance coordinate, d digest, e expiry, and E the admitted evidence set. A model-derived proposal P may later request persistent state change. The benchmark perturbs one relevant dependency between issuance of H and the commit attempt for P while preserving the task and payload shape as far as the schedule allows.

We assume authenticated requests, stale client state, potentially overreaching users, conflicting or untrusted text in evidence, and legitimate concurrent updates. The study does not assume database-administrator compromise, stolen infrastructure secrets, or production patient data. Headline runs use synthetic subjects and unique sentinel values.

III. BENCHMARK DESIGN

A. Matched schedules

Table II fixes the core schedule families before the final run. A logical schedule, not an HTTP retry or model call, is the statistical unit.

TABLE I
CROSS-BENCHMARK CAPABILITY COMPARISON: THREAT DIMENSION
COVERAGE IN STATEFUL CLINICAL AGENT SECURITY.

Benchmark	Prompt	Attack	Tool Access	TOCTOU	Drift	Consent	Revoke
			Merkle Trace				
			AgentDojo [1]	×	×	×	×
			MPIB [3]	×	×	×	×
			CommitGuard [2]	×	×	×	×
			Provenact [2]	×	×	×	×
			GateMem [7]	×	×	×	×
			GovRed-Health (Ours)				

TABLE II
CORE AUTHORIZATION-DRIFT SCHEDULES.

Schedule	Primary invariant
Disclosure → consent re- voke → commit	Revoked authority cannot license a later disclosure- derived commit.
Disclosure → policy up- date → commit	Policy drift is revalidated at durability.
Disclosure → actor/role/purpose change	Authorization coordinates cannot silently rebind.
Subject-cross replay	Snapshot/proposal cannot migrate across subjects.
State advance → stale commit	Stale base state cannot overwrite newer state.
Revoke → derived-cache reuse	Derived state cannot preserve revoked disclosure authority.
Expiry/digest invalidation	Invalid disclosure witnesses cannot authorize commit.
Governance writer proposal commit	Outcome must match the governance state that linearizes first; unresolved ordering remains inde- terminate.
Audit reconstruction	Disclosure, mutation, decision, and effect remain reconstructable.

B. Mechanism ablations

The isolated study uses four configurations on the same research application path.

- **UNBOUND**: persistent proposal admission without snapshot/write binding.
- **STATE_VERSION_ONLY**: base state version is revali-
dated, but the exact disclosure is not bound.
- **SNAPSHOT_BOUND_STATE_ONLY**: proposal is
bound to a snapshot/state coordinate, without strict
commit-time governance revalidation.
- **GLHS_STRICT**: exact snapshot coordinates plus state
and relevant governance are revalidated before persistence.

An arm/case pair that cannot be implemented faithfully is reported as not applicable or not run under a prespecified rule; it is never converted to a zero failure rate.

C. Real-boundary execution

Headline observations traverse the isolated deployment through ordinary HTTP requests and the application path into PostgreSQL, Redis/cache where applicable, and audit/reconstruction logic. Store observers are read-only with respect to the measured outcome. In particular, the measurement route must not create the expected result (for example, by deleting a cache entry solely because the selected arm is strict) and then count that deletion as independent evidence of cache invalidation.

Each case records normalized response class, relevant before/after state coordinates, commit occurrence, transition/audit

TABLE III
SEALED FINAL-RUN OUTCOMES. THE FIRST COLUMN IS THE PRESPECIFIED
ORIGINAL NON-SAFE COMPOSITE, NOT A CONFIRMED-INVALID-COMMIT
RATE. ALL 30 STRICT RESIDUALS ARE INDETERMINATE
CONCURRENT-ORDERING SCHEDULES. RAW AUDIT COUNTS ARE OMITTED
BECAUSE AUDIT-ELIGIBLE OPPORTUNITIES DIFFER BY ARM AND REQUIRE
CONDITIONAL DENOMINATORS.

Arm	Original non-safe composite (95% CI)	Prohibited disclosure
UNBOUND	120/210; 0.571 (0.504–0.636)	0/270
STATE_VERSION ONLY	90/210; 0.429 (0.364–0.496)	0/270
SNAPSHOT_BOUND STATE_ONLY	90/210; 0.429 (0.364–0.496)	0/270
GLHS_STRICT	30/210; 0.143 (0.102–0.197)	0/270

observations, cache presence or reuse where applicable, response hash, and latency. Raw secrets and unnecessary payload content are excluded from public artifacts.

D. Oracles

Deterministic sentinels and state/audit assertions score observable boundary properties without asking an LLM to grade its own behavior. Oracles cover wrong-subject exposure, prohibited sentinel release, stale/invalid commit acceptance, snapshot expiry/digest acceptance, governance invalidation, and audit reconstruction. Model-based methodological review may inspect the protocol but is not used as the primary runtime oracle.

IV. ANALYSIS PLAN

For each compatible arm, the final report gives numerators, denominators, and 95% Wilson intervals for the frozen original non-safe composite and prohibited-disclosure rate. Confirmed invalid/stale commits, confirmed safe/rejected outcomes, and indeterminate concurrent ordering are interpreted as distinct outcome classes; the composite is retained for preregistered reproducibility rather than treated as a confirmed-violation rate. Matched binary arm comparisons use exact McNemar tests where applicable; prespecified comparison families use Holm adjustment. Secondary outcomes include cache/governance revalidation behavior, rejected-operation auditability, committed-operation reconstructability, p50/p95 latency, and availability/retry cost.

A defensive rejection is distinct from transport or infrastructure failure. Race schedules retain an INDETERMINATE state when the required ordering cannot be established from the recorded timing/transaction evidence. Repeated low-level retries do not increase N .

V. RESULTS

A. Final four-arm boundary outcomes

The sealed run 2026-08-17-rivf-final-003, frozen at source revision 5b2c0dbf17e2, executed 270 synthetic logical schedules per arm. The original primary non-safe composite included 210 executable mandatory-primary schedules per arm; 180 protocol-excluded/unsupported rows per arm remained NOT RUN and were excluded from denominators.

The exact paired McNemar comparison between GLHS_STRICT and UNBOUND on identical primary logical cases gave $b = 90$, $c = 0$, and $p = 1.62 \times 10^{-27}$. All 30 GLHS_STRICT primary residuals were concurrent-stale-state-write schedules with indeterminate ordering; they are reported as a third outcome category rather than confirmed failures or successes. Serial authorization-drift families yielded zero confirmed invalid Strict commits.

B. Audit, cache, concurrency, and claim boundary

Cache/index observation was measurement-only: the adapter did not directly invalidate the measured cache path, and cache-revocation failure was 0/270 in every arm under that observer contract. Prohibited disclosure was also 0/270 for every arm. These zeros apply only to the executed benchmark schedules and do not establish a general privacy or deployment-security guarantee. The 180 NOT RUN rows per arm remain explicit protocol exclusions rather than successes. Audit completeness will be reported only against prespecified eligible opportunities (for example, rejected operations requiring a rejection decision record and committed operations requiring exact reconstruction). Rejection-auditability controls and a fresh confirmatory holdout remain future evidence gates; the present paper therefore reports a sealed controlled robustness experiment, not production cybersecurity validation.

VI. DISCUSSION

The benchmark exposes a distinction that endpoint-success metrics can hide: a request may complete even though the authority or governed disclosure that justified the persistent effect is stale. The mechanism arms help separate state freshness, governance freshness, and exact disclosure binding rather than treating them as one undifferentiated security property.

The sealed result is encouraging but bounded. Strict removed the serial authorization-drift failures exercised by the benchmark, while the remaining Strict composite residuals occurred only in concurrent stale-state schedules with indeterminate ordering and are not classified as confirmed failures. This does not establish universal concurrency safety. Zero prohibited disclosure in the tested schedules likewise does not establish a general confidentiality guarantee. The benchmark is most useful as a diagnostic tool for identifying which dependency a system revalidates and where residual failures remain.

VII. LIMITATIONS AND ETHICS

The study uses synthetic subjects and one application architecture, so external validity to other EHR stacks and authorization models is limited. Sentinel oracles cover observable disclosure and persistence failures, not every semantic privacy harm. Downgraded arms are research configurations only. The benchmark does not evaluate diagnosis, treatment, patient outcomes, legal compliance, or resistance to privileged infrastructure compromise.

VIII. REPRODUCIBILITY

A claim-eligible run binds the frozen case manifest, statistics plan, exact source revision, arm implementation, isolated environment contract, database/cache configuration, timestamps, raw observations, and a SHA-256 inventory under an immutable run ID. Material post-freeze changes require a new run ID. Tables and figures are generated from the same sealed machine-readable results; missing work remains explicitly not run.

IX. CONCLUSION

GovRed-Health defines a real-boundary benchmark for authorization drift between a model-consumed governed health disclosure and a later persistent commit. In the sealed executable primary schedules, GLHS-Strict reduced the original composite non-safe endpoint from 57.1% in Unbound to 14.3%. The entire Strict residual was indeterminate concurrency, while confirmed invalid Strict commits were absent in the tested serial authorization-drift families. The contribution is the matched disclosure–mutation–commit schedule and its end-to-end observability, not a new authorization mechanism. The result supports a bounded synthetic software claim under the frozen schedules, not production cybersecurity or clinical effectiveness.

REFERENCES

- [1] E. DeBenedetti, J. Zhang, M. Balunović, L. Beurer-Kellner, M. Fischer, and F. Tramèr, “AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents,” in *Advances in Neural Information Processing Systems*, Datasets and Benchmarks Track, 2024.
- [2] H. Zhang, J. Huang, K. Mei, Y. Yao, Z. Wang, C. Zhan, H. Wang, and Y. Zhang, “Agent Security Bench (ASB): Formalizing and benchmarking attacks and defenses in LLM-based agents,” in *International Conference on Learning Representations*, 2025.
- [3] J. Lee, H. Jang, and K. S. Choi, “MPIB: A benchmark for medical prompt injection attacks and clinical safety in LLMs,” arXiv:2602.06268, 2026.
- [4] Y. Ma and S. Schmid, “SecureClaw: Clawing back control of LLM agents,” arXiv:2606.09549, 2026.
- [5] I. Santos-Grueiro, “Temporary Authority, Permanent Effects: Commit-time authorization for LLM agents,” arXiv:2607.10487, 2026.
- [6] Y. Peng and X. Wu, “Stateful governance for concurrent agentic systems,” arXiv:2608.02764, 2026.
- [7] Z. Ren, Y. Yang, Y. Chen, et al., “GateMem: Benchmarking memory governance in multi-principal shared-memory agents,” arXiv:2606.18829, 2026.
- [8] HL7 International, “FHIR R4: Consent,” 2019.
- [9] HL7 International, “FHIR R4: Provenance,” 2019.